

Risk Acceptance Form

NOVAtech Inc. | Vulnerability Management Program | Simulated for demonstration

SECTION 1 - IDENTIFICATION	
Risk Acceptance ID	RA-2026-04
Date submitted	2026-07-15
Submitted by	Marcus Reid, Engineering Lead
Related risk register entry	R-02 (Exploitation of unpatched critical vulnerability on internet-facing application)
Related asset(s)	legacy-reports-01 (internal reporting server)
SECTION 2 - VULNERABILITY DETAILS	
Vulnerability ID / CVE	CVE-2025-XXXX
Affected component	Reporting middleware library v2.4.1 running on an unsupported OS component
CVSS base score	8.1 (High)
Exploitability signals	Not on CISA KEV as of assessment date; EPSS score 0.08 (low probability); no public exploit code observed
Detection source	Nessus authenticated scan, cycle 2026-07-12
Standard SLA per policy	30 days (High severity, internal system)
Would-be remediation date	2026-08-11
SECTION 3 - BUSINESS JUSTIFICATION	
Reason remediation cannot meet SLA	The affected reporting middleware runs on an unsupported OS component. The vendor patch requires a full OS migration currently scheduled for Q4 2026 (target completion 2026-10-31). Migration cannot be accelerated without disrupting the finance close cycle and Q3 board-report deliverables. Piecemeal patching of the affected library on the unsupported OS is not supported by the vendor and would leave the system in an unsupportable state.
Business impact of unmitigated remediation	Q3 board reporting delay (2-3 weeks); disruption to finance close for August and September; estimated \$180K in delayed revenue-recognition impact
SECTION 4 - COMPENSATING CONTROLS	
Compensating controls applied	1) Host isolated to dedicated VLAN with no direct internet access. 2) Access restricted to 4 named analysts via MFA-enforced jump host; all sessions logged. 3) EDR agent set to block mode for suspicious execution patterns. 4) Weekly log-review use case added to Splunk targeting anomalous authentication and process execution on this host. 5) Compensating controls to be re-verified monthly by Security Operations.
SECTION 5 - RESIDUAL RISK ASSESSMENT	
Inherent risk (before compensating controls)	L3 x I4 = 12 (High). Aligned with R-02 in the enterprise risk register.
Residual risk (with compensating controls)	L2 x I3 = 6 (Medium). Within the appetite threshold of ≤6 defined in the Risk Management Framework.
Justification for residual score	Likelihood reduced from L3 to L2: network isolation and access restriction remove opportunistic exploitation paths; EDR blocking reduces successful execution likelihood if credentials are compromised. Impact reduced from I4 to I3: successful compromise would be

	contained to a single non-production reporting host with no customer data; blast radius bounded by segmentation.
SECTION 6 - DURATION AND REVIEW	
Requested exception term	90 days: 2026-07-15 to 2026-10-13
Renewal expectations	No renewal expected. OS migration completes 2026-10-31, at which point standard remediation applies.
Trigger for early termination	(a) Vulnerability appears on CISA KEV list; (b) EPSS score rises above 0.5; (c) OS migration completes ahead of schedule; (d) compensating controls are found ineffective during monthly re-verification.
Review schedule	Monthly compensating-control verification (Security Operations); mid-term review by GRC at 45 days; expiry review at 90 days.
SECTION 7 - APPROVALS	
Asset owner	Marcus Reid, Engineering Lead — Approved 2026-07-15
Security Operations review	Priya Sharma, SecOps Analyst — Verified compensating controls in place 2026-07-15
Risk Acceptance Authority	Anna Chen, Head of Security — APPROVED 2026-07-16
CTO notification	Sent 2026-07-16 (no CTO approval required for 90-day term)

POST-APPROVAL REGISTER ENTRY

RA-2026-04 is entered into the Exception Register with expiry date 2026-10-13. Owner: Engineering Lead. Linked to enterprise risk R-02. Monthly compensating-control verification assigned to Security Operations. Mid-term review scheduled for 2026-08-29. Register reviewed monthly at the security operations meeting and quarterly at the management review.